



DrishtiSec

Security Validation Report

Assessment Date 2026-09-09 05:57 UTC

Assessment Target PresensiKu – Employee Attendance System

Environment Isolated Lab (192.168.200.128:8080)

Assessment Type Web Application Security Assessment

Executive Summary

This report documents controlled security validation activity performed against an isolated laboratory target. Three representative attack patterns identified in prior WAF analysis were reproduced against a deliberately vulnerable application to confirm the underlying technical behavior. All three validation scenarios completed successfully.

This validation was performed entirely within an isolated laboratory environment. It does not represent, and must not be interpreted as, exploitation of any production system.

WAF Findings

Finding	Pattern	Validation	Status
SP_Asset-006	OS Command Injection	VAL-CMD-001	Validated
SP_Asset-007	Local File Inclusion (LFI)	VAL-LFI-001	Validated
SP_Asset-008	Local File Inclusion (LFI)	VAL-LFI-001	Validated
SP_Asset-009	Directory Traversal	VAL-TRAV-001	Validated
SP_Asset-011	Directory Traversal	VAL-TRAV-001	Validated

Validation Results

VAL-CMD-001 – OS Command Injection

Status: VALIDATED WAF Reference: SP_Asset-006 Endpoint: /admin/config

WAF request pattern: /admin/config?cmd=cat/root/.aws/credentials

Local evidence: lab-data/root/.aws/credentials

WAF evidence: GET-based request pattern. Laboratory validation: GET and POST. POST was added as an additional controlled test of the same execution primitive and was NOT observed in the original WAF evidence.

VAL-LFI-001 – Local File Inclusion (LFI)

Status: VALIDATED WAF Reference: SP_Asset-007 / SP_Asset-008 Endpoint: /read

WAF request pattern: /read?file=../../.env

Local evidence: lab-data/.env

WAF evidence and laboratory validation both used GET.

VAL-TRAV-001 – Directory Traversal

Status: VALIDATED WAF Reference: SP_Asset-009 / SP_Asset-011 Endpoint: /

WAF request pattern: /?file=../../.env

Local evidence: lab-data/traversal-target/.env

WAF evidence and laboratory validation both used GET.

Evidence

VAL-CMD-001 – OS Command Injection

timestamp=2026-09-09T12:48:33+0700 source_ip=192.168.200.128 method=GET

endpoint=/admin/config status=EXECUTED

Operating-system command executed successfully

VAL-LFI-001 – Local File Inclusion (LFI)

No application log entry captured yet for this scenario.

VAL-TRAV-001 – Directory Traversal

timestamp=2026-09-09T09:03:57+0700 source_ip=192.168.200.128 method=GET endpoint=/read

status=READ_OK

READ_OK

Findings

VAL-CMD-001 – OS Command Injection (Severity: High)

The /admin/config endpoint passes the supplied cmd value directly into a shell command with no sanitization or allow-listing, allowing arbitrary operating-system command execution.

Business Impact: An attacker able to reach this endpoint could execute arbitrary commands with the privileges of the application process, potentially leading to full host compromise.

VAL-LFI-001 – Local File Inclusion (LFI) (Severity: High)

The /read endpoint joins the supplied file value onto its intended documents directory with no normalization or allow-listing, so "../" segments escape it and include the contents of arbitrary local files.

Business Impact: An attacker able to reach this endpoint could read local application files, potentially exposing configuration or credential material.

VAL-TRAV-001 – Directory Traversal (Severity: High)

The / endpoint joins a supplied file value onto its own intended assets directory with no normalization, so "../" segments escape it and reach internal application/HR configuration outside the intended directory. This is the same underlying primitive as VAL-LFI-001, reached through a different application entry point (the homepage route rather than /read) and escaping to a different, distinct resource so the two findings' impact is clearly distinguishable.

Business Impact: An attacker able to reach this endpoint could read internal application and HR infrastructure configuration outside the intended public directory.

Conclusion

All three representative attack patterns were successfully reproduced against the isolated laboratory target, confirming the underlying vulnerable behavior identified by prior WAF analysis. This constitutes successful controlled reproduction in an isolated vulnerable environment, not exploitation of a production system.